Monthly Intelligence Dispatch

December 2019 &
Results of the year

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- The North Korean threat group Lazarus uses new tools: a remote access Trojan (RAT) dubbed **Dacls**, **TrickBot**, and **Anchor** to infect their targets.
- The data of more than **460,000** cards of **Turkish** banks' customers was put up for sale on Joker's Stash, a card shop.
- Throughout 2019, Group-IB specialists recorded a flurry of phishing activity against the customers of **Credit Mutuel**.
- Since mid-December 2019, Group-IB specialists have been observing mail-outs to Russian companies, with emails containing a modified version of RMS, a legitimate remote access program.
- Phishing pages that copy **Netflix**, **PayPal**, and **Boursorama bank** are sold on underground forums.
- A loader based on the **EternalBlue** exploit was put up for sale on an underground forum. EternalBlue was used in 2017 to distribute **WannaCry** and **Petya** ransomware.
- The owner of a network of pirate streaming services was convicted on charges of an offense under part 3 of article 146 of the Russian Criminal code "Violation of copyright and related rights." They were sentenced to two years' suspended imprisonment. This is the first such case in Russia.

Group-IB experts consider the use of cyberweapons in military operations to be the leading and most frightening trend of 2019. Attacks on critical infrastructure and targeted destabilization of the Internet in certain countries are breaking new ground on cyberattacks. The first six months of 2019 saw three overt military operations: in March, most of Venezuela was left without electricity for several days as a result of an attack on one of the country's hydroelectric plants; in May, the Israel Defense Forces launched an airstrike against hackers from the militant group Hamas; and in June, the United States used cyberweapons against Iranian missile-control systems in retaliation for the shootdown of a US drone. The tools used in the attacks have not been identified. In the latter case, however, the cyberattack occurred only a few days after the drone incident. This confirms the suggestion that the critical infrastructure of many countries has already been compromised, but attackers remain unnoticed until they act.

In 2019, the activity of **38** groups (with **7** of them being new cyberespionage groups) was discovered. This does not mean that other well-known groups ceased their activity, however. It is more likely that their campaigns simply remained under the radar. In the energy sector, for instance, only two frameworks capable of affecting processes were detected: **Industroyer** and **Triton (Trisis)**. Both were found as a result of an error on the part of their operators. It is clear that many threats remain undetected, which is a ticking time bomb. In 2019, cases where threat actors disguised as hacktivists or former group members released information about attack tools used by other groups became more frequent. They were most often examples of hacking back, when attackers become the victims.

RMS

Since December 19, 2019, Group-IB specialists have been observing mail-outs to Russian companies, with emails containing a modified version of RMS with backdoor functionality. RMS is a legitimate remote access program, but threat actors can use modified versions of it for malicious purposes. The mail-outs have been carried out under the name of **Angarsk Electrochemical Combine**, but the actual senders are different. The emails have an archive attached, which contains two documents and a password-protected archive with malware disguised as **Seldon** installer (software for working with tenders).

Lazarus

It was reported in December that the North Korean threat group Lazarus used new tools: a RAT dubbed **Dacls**, **TrickBot**, and **Anchor** to infect their targets. Netlab 360 specialists observed a campaign that distributed **Dacls**, which is a modular RAT that attacks both Windows and Linux computers by exploiting a remote code execution vulnerability in a macro in the Atlassian Confluence system. The vulnerability was fixed in March 2019. The experts link Dacls activity to Lazarus. Earlier reports suggest that the North Korean hackers buy access to infected systems from Trickbot operators and use a new Trickbot module dubbed Anchor. Trickbot is one of today's top three botnets along with Emotet and Dridex.

Currently, only five groups pose a real threat to the financial sector: Cobalt, Silence, MoneyTaker (Russia), Lazarus (North Korea), and SilentCards (a new group from Kenya). In Russia, damage from targeted attacks on banks carried out by financially motivated threat groups has dwindled almost 14-fold. One of the reasons is that Russian-speaking threat actors have been shifting to banks worldwide.

In 2019, Group-IB detected attacks by a new group called RedCurl. The group's main goals are cyberespionage and financial theft. Once important documentation has been exfiltrated, the hackers install miners in the compromised company's infrastructure. The group's distinctive feature is the high quality of their phishing attacks, as part of which they tailor emails to the company they are targeting. The threat actor uses a unique custom Trojan that communicates with the C&C server via legitimate services, which makes it very difficult to detect its malicious activity in infrastructures.

In its Hi-Tech Crime Trends 2019–2020 report, Group-IB notes that the damage from all types of cybercrime that involves malware and targets banks and banking customers declined, resulting in a record-breaking 85% market drop. Group-IB estimates that the Russian hi-tech crime market in the financial sector shrank to $8,000 between H2 2018 and H1 2019, compared to $51 million in the previous period. With financially motivated threat groups leaving the .RU zone and the number of Android Trojans and groups engaged in phishing going down, attacks against banking customers involving social engineering and phone fraud in Russia are on the rise.

Joker's Stash

The data of more than **460,000** cards of **Turkish** banks' customers was put up for sale on Joker's Stash, a card shop. On October 28, 2019, Group-IB detected two parts of a database called **TURKEY-MIX**. The two parts contained the data of **60,000** bank cards. Later, on November 27, 2019, another two parts of the database were published on the same resource containing the data of **400,000** cards. Over **99%** of the cards from this database belong to Turkish banks. This is the only major sale of payment cards affecting Turkish banks in the last year. Group-IB experts estimate the price of the database on the black market at **$500,000**. In October 2019, Group-IB's Threat Intelligence experts discovered an immense database on Joker's Stash. The database contains over 1.3 million entries with credit and debit card data. More than 98% of them belonged to the customers of Indian banks. The price of the database was estimated at more than **$130 million**.

Credit Mutuel

Throughout 2019, Group-IB specialists recorded a flurry of phishing activity against the customers of **Credit Mutuel**. Analysis revealed the phishing kit developer's identity. A phishing kit is the web component (backend) of a phishing site. Phishing kits are designed to copy legitimate resources (in this case Credit Mutuel) and/or steal user data or infects victim computers with a malicious script. Organization-specific phishing kit development services as well as ready-made phishing kits that mimic several popular services, such as Facebook, Outlook, and others are often advertised on various underground platforms.

RTM	Group-IB specialists obtained information about a number of infected computers in the RTM botnet and identified an actual command and control (C&C) server hidden behind a proxy. In 2019, RTM started using Bitcoin wallets to specify C&C servers for the MAIN and RECON modules. Analysis of the servers specified in transactions has revealed that they are proxy servers that redirect traffic to a server in Germany, which has been active since May 2019. Investigation into the botnet has shown that at least 5,368 computers are infected with the Trojan. Initial information about 3,316 computers has been obtained. These are mostly computers in Russia, Ukraine, Belarus, and Kazakhstan. There are, however, several infected stations in Azerbaijan. The main targets are small and medium-sized businesses, but there also targeted computers in the infrastructures of large businesses and government agencies.
Phishing	A user nicknamed zero0day made a post about selling **Amazon**, **Apple**, **Outlook**, and **Microsoft Office 365** phishing pages, mainly targeted at customers in the US, Canada, and the UK. The threat actor's team can create any phishing pages upon request within three days. The price for one page starts at $50. The threat actor said they had two pages at the moment with full customer information gathered from services such as **Netflix**, **PayPal**, and **Boursorama bank**.

CVE-2019-1458	In December 2019, a user named netstat made a post on Exploit.in, an underground forum, about selling a zero-day exploit for the CVE-2019-1458 (LPE) vulnerability. This privilege escalation vulnerability occurs in Windows when the Win32k.sys component fails to properly handle objects in memory. An attacker who successfully exploited this vulnerability could run arbitrary code in kernel mode, which would allow them to install programs; view, change, or delete data; or create new accounts with full user rights. Microsoft issued a patch for the vulnerability on December 10, 2019.
EternalBlue	A user with the nickname ghostrider made a post on Exploit.in about selling a loader based on the **EternalBlue** exploit. The malware is an archive that contains about 100 files, most of which are Microsoft Visual Studio library files. The EternalBlue exploit was published by the **Shadow Brokers** hacking group in April 2017. The exploit is aimed at exploiting a vulnerability in the Microsoft SMBv1 server. The exploitation of several vulnerabilities led to an epidemic with WannaCry and Petya ransomware in 2017. Microsoft issued patches that fixed the vulnerability in Windows, including for non-supported Windows XP, 7, and Windows Server 2003.

RAT+HVNC	The source code of RAT+Hidden VNC, a remote access Trojan, was put up for sale on Exploit.in, an underground forum. The malware runs on Windows 7–10 and has the following functionality: keylogger, loader, remote access, etc. The initial price for the source code was $2,000, but it went down to $1,000 after the first copy had been sold.
Hidden VNC	Slightly earlier, in November 2019, new private software for hidden remote desktop access, which runs on Windows (from XP to 10), was put up for rent on the same forum. The author is a user named ScanHaven, who offered opportunities to work on **Iran**, the **UAE**, **Turkey**, **Japan**, **South Korea**, and **China**. Most likely, the author was looking for partners to carry out targeted attacks using Cobalt Strike and Meterpreter. This is not the first time the author has sold malware on forums. They used to offer banking bots, form grabbers, and ScanHaven (a web service for checking files with various antivirus software).
BFG	In late 2019, a new Android bot called BFG was put up for rent on xss.is, an underground forum. The bot's functionality includes SMS, calls, contacts, GPS, applications (including banking apps), and injects. The author of the program is a user named "BFG." One of the bot's advantages, the author says, is that it is highly automated. Data loading, notifications about banking apps, and injects work in automated mode, which makes working with the bot much easier. On December 10, 2019, the forum administration blocked BFG (the user) for thefts.

Arrests and sentences

kinogb.guru

On December 19, 2019, a Moscow Region court convicted the owner of pirate streaming services on charges of an offence under part 3 of article 146 of the Russian Criminal Code "Violation of copyright and related rights." The pirate made money on showing illegal video content: latest films, popular movies, and TV series. The court sentenced the accused to two years' suspended imprisonment. This is the first such legal case in Russia. As early as 2018, Group-IB's Anti-piracy specialists detected a large network of pirate online streaming services, which comprised kinogb.guru, kinokot.biz, and fosa.me, as well as their mirrors, including kinogb.site, kinogb.me, kinogb.life , kinogb.cc , kinogb.mobi, kinokot.me, and kinogb.tv. Each website's pirate library numbered over 10,000 items: latest films and other popular movies and TV series. The pirate received content from one of the biggest pirate content distribution networks (CDNs) called Moonwalk, which was taken down in October 2019. The advertisers of the pirate websites were, as usual, 1xbet and Azino777—online casinos that also used CDN providers to offer video content with embedded ads.

Imminent Monitor

In cooperation with law enforcement agencies in Colombia and Australia, Europol took down a Trojan called Imminent Monitor. Authorities shut down the servers of the project, which had been promoted as a legitimate utility but had all the functionality of a remote access Trojan (RAT). The malware was purchased by over **14,000** users, who distributed it in **124** countries. The active phase of the operation started in the summer of 2019, when Australian and Belgian police obtained warrants to arrest the malware's author and one of their assistants. Actions were taken in Czechia, the UK, Colombia, Poland, Spain, Sweden, and the Netherlands. 13 of the Trojan's most prolific users were arrested and 430 devices were seized. Forensic analysis of the equipment seized during the operation is ongoing.

Forecasts and warnings

- Scenarios in which a country could be disconnected from the Internet seemed unrealistic, yet they are becoming increasingly likely. Domain name registrars are part of critical infrastructures. Disrupting their work affects the World Wide Web, which is why registrars are targeted by government-sponsored threat actors. Next year, there will be a high risk of more threat actors carrying out successful attacks, including for sabotage purposes.
- IT networks will remain the main attack vector for threat actors. Access to these segments is crucial for espionage and collecting information about how to attack a particular energy company for sabotage purposes. OT network compromise will be the next step once the network's IT segment is successfully breached.
- Russian-speaking groups (Silence, MoneyTaker, and Cobalt) are likely to continue their expansion by multiplying their attacks outside Russia. To withdraw money, they will carry out attacks on card processing systems and use Trojans for ATMs. The groups will shift their focus away from SWIFT.
- Lazarus will remain the only group to steal money through SWIFT and ATM Switch. The threat actor has previously carried out successful attacks through ATM Switch against banks that use software running on IBM AIX. Such banks will therefore be the first to catch the threat group's attention.
- Infrastructure disruption to cover tracks will be the final stage of successful attacks.
- SilentCards may remain local and focus on African banks. The group is likely to expand its list of targets by attacking other industries. Their main vector will be blackmail in ransomware attacks.
- The Trickbot Trojan has markedly improved and can now be used in targeted attacks on banks and for espionage against government agencies, as was the case with the Zeus Trojan.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organisation.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com